



 slington college
(इस्लिङ्टन कलेज)

Module Code & Module Title

CC5052NI Risk, Crisis and Security Management

Assessment Weightage & Type

50% Individual Coursework

Year and Semester

2025 -26 Autumn Semester

Student Name: Aashutosh Poudyal

London Met ID: 24046334

College ID: NP01NT4A240026

Assignment Due Date: 21 Jan. 26

Assignment Submission Date: 25 Jan. 26

Word Count (Where Required):1650

I confirm that I understand my coursework needs to be submitted online via MST under the relevant module page before the deadline for my assignment to be accepted and marked. I am fully aware that late submissions will be treated as non-submission and a mark of zero will be awarded.

Final Coursework Submission

 Islington College, Nepal

Document Details

Submission ID

trn:old::3618:126572796

Submission Date

Jan 20, 2026, 5:02 PM GMT+5:45

Download Date

Jan 20, 2026, 9:07 PM GMT+5:45

File Name

aaashu simi.docx

File Size

33.9 KB

17 Pages

2,370 Words

14,818 Characters



14% Overall Similarity

The combined total of all matches, including overlapping sources, for each database.

Filtered from the Report

- Small Matches (less than 8 words)

Exclusions

- 5 Excluded Sources

Match Groups

-  **16 Not Cited or Quoted 7%**
Matches with neither in-text citation nor quotation marks
-  **14 Missing Quotations 7%**
Matches that are still very similar to source material
-  **0 Missing Citation 0%**
Matches that have quotation marks, but no in-text citation
-  **0 Cited and Quoted 0%**
Matches with in-text citation present, but no quotation marks

Top Sources

- 6%  Internet sources
- 2%  Publications
- 13%  Submitted works (Student Papers)

Integrity Flags

0 Integrity Flags for Review

Our system's algorithms look deeply at a document for any inconsistencies that would set it apart from a normal submission. If we notice something strange, we flag it for you to review.

A Flag is not necessarily an indicator of a problem. However, we'd recommend you focus your attention there for further review.

Match Groups

- 16 Not Cited or Quoted 7%**
Matches with neither in-text citation nor quotation marks
- 14 Missing Quotations 7%**
Matches that are still very similar to source material
- 0 Missing Citation 0%**
Matches that have quotation marks, but no in-text citation
- 0 Cited and Quoted 0%**
Matches with in-text citation present, but no quotation marks

Top Sources

- 6% Internet sources
- 2% Publications
- 13% Submitted works (Student Papers)

Top Sources

The sources with the highest number of matches within the submission. Overlapping sources will not be displayed.

1	Submitted works	Apex Australia Higher Education on 2025-10-13	2%
2	Submitted works	Islington College,Nepal on 2026-01-16	<1%
3	Internet	www.metricstream.com	<1%
4	Internet	safetyculture.com	<1%
5	Internet	www.researchgate.net	<1%
6	Internet	data.nanet.go.kr	<1%
7	Submitted works	ESoft Metro Campus, Sri Lanka on 2025-06-29	<1%

Abstract

Businesses now face an ever-growing digital environment, which creates complex cyber threats that endanger their operational stability, financial health, and essential infrastructure systems. The report studies risk management and risk control principles through its analysis of ISO 31000 and COSO ERM and ISO/IEC 27005, which provide organizations with structured systems to detect and evaluate risks and create defense strategies that match their business needs and legal standards.

The report studies two major cyber incidents to show their real-world effects through the SolarWinds supply chain attack and the Colonial Pipeline ransomware attack. The case studies reveal that supply chain security flaws, together with poor authentication systems and monitoring weaknesses, resulted in major operational damage and financial losses. The ISO/IEC 27005 framework enables the report to demonstrate that organizations need to identify risks before they happen. This maintains proper control systems and ongoing surveillance to build better cybersecurity defense and safeguard their vital infrastructure systems.

Table of Contents

1. Introduction to Risk Management and Risk Control	1
1.1 Rationale	3
2. Literature Review	4
2.1 Risk Management Frameworks	4
2.2 Risk Management Process	6
3. Literature Review summary	8
4. Case Studies	9
4.1 Case Study I SolarWinds supply chain attack	9
4.1.1 Background	9
4.1.2 Issue Identification	10
4.1.3 Mitigation Risk Management using ISO 27005 Framework	11
4.1.4 Case Study Summary	12
4.2 Case Study II Colonial Pipeline ransomware attack	12
4.2.1 Background	12
4.2.2 Issue Identification	14
4.2.3 Mitigation Risk Management using ISO 27005 Framework	15
4.2.4 Case Study Summary	16
4. References	17
Bibliography	17
5. Appendix	21
5.1 Aims and Objectives	21
5.2. ISO 31000 Risk Management Framework	22
5.3 COSO Enterprise Risk Management (ERM)	22
5.4 ISO 27005 – Information Security Risk Management	23
5.5 Risk Identification	25
5.6 Risk Assessment	25
5.7 Risk control	27

Figure 1 Global risks landscape (Sekol, 2023).....	1
Figure 2 Ad spend forecasts (dentsu, 2023)	2
Figure 3 Risk Management Framework (Villanueva, 2024).....	4
Figure 4 Principles, framework and process (iso, 2018).....	22
Figure 5 Enterprise Risk Management (Williams, March 11, 2019)	23
Figure 6 5 Benefits of ISO/IEC 27005 (PECB, n.d.).....	24
Figure 7 Risk Management Process (Horvath, May 27 2025).....	6
Figure 8 Benefits of risk identification (metricstream, 2024).....	25
Figure 9 Assessment matrix (riskpal, n.d.)	26
Figure 10 Risk Control (riskpal, n.d.)	27
Figure 11 Timeline of the SolarWinds Supply Chain Attack (Burkett, January 19th, 2021)	9
Figure 12 The Anatomy of the SolarWinds Attack Chain (cyberark, 2/23/2021).....	10
Figure 13 Simplified ISO/IEC 27005 Risk Management Process (Forêt, September 11, 2023).....	11
Figure 14 Ransomware attack on Colonial Pipeline (economist, May 10th 2021).....	13
Figure 15 ISO/IEC 27005 Risk Management Process Diagram (Alazzawi, 2021).....	15

1.Introduction to Risk Management and Risk Control

Modern organisations function in a complex and interconnected risk environment which has become standard in the digital age. The combination of fast technological progress and worldwide supply networks and regulatory demands and increasing dependence on information systems has created numerous new risks for businesses to manage (Aven, 16 August 2016)



Figure 1 Global risks landscape (Sekol, 2023)

The digital environment of today shows that worldwide digital transformation spending has reached new heights because of artificial intelligence progress, cloud computing development, and system network expansion which will exceed \$2 trillion by 2026.

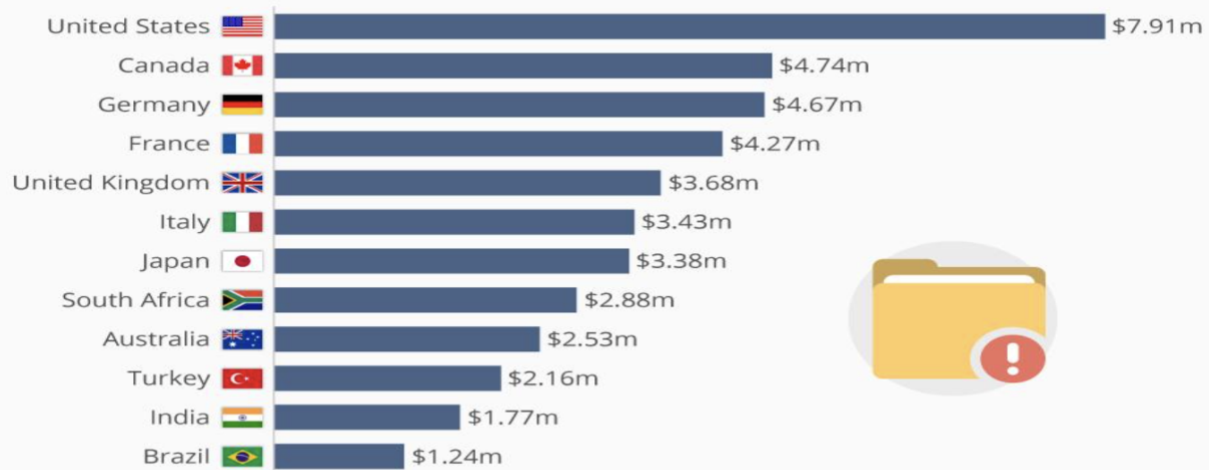
	2022	2023	2024f	2025f	2026f
Total advertising spend (\$B)	695.6	718.6	754.4	785.9	819.1
YOY Growth (%)	8.2	3.3	5.0	4.2	4.2
Digital (\$B)	388.8	418.3	449.3	478.6	508.0
Share of total spend (%)	55.9	58.2	59.6	60.9	62.0
YOY growth (%)	15.0	7.6	7.4	6.5	6.1
Television (\$B)	173.4	165.7	170.0	171.7	174.0
Share of total spend (%)	24.9	23.1	22.5	21.8	21.2
YOY growth (%)	-0.4	-4.4	2.6	1.0	1.3
Print (\$B)	50.1	47.4	46.2	45.0	44.1
Share of total spend (%)	7.2	6.6	6.1	5.7	5.4
YOY growth (%)	-5.0	-5.5	-2.6	-2.4	-2.1
Out-of-Home (\$B)	37.4	41.0	42.7	44.5	46.6
Share of total spend (%)	5.4	5.7	5.7	5.7	5.7
YOY growth (%)	11.4	9.5	4.2	4.2	4.8
Audio (\$B)	35.2	35.5	35.6	36.0	36.4
Share of total spend (%)	5.1	4.9	4.7	4.6	4.4
YOY growth (%)	4.2	0.8	0.4	1.1	0.9
Cinema (\$B)	2.5	2.4	2.5	2.6	2.6
Share of total spend (%)	0.4	0.3	0.3	0.3	0.3
YOY growth (%)	27.5	-1.4	4.8	2.2	1.8

Figure 2 Ad spend forecasts (dentsu, 2023)

The expanding internet-based networks have generated multiple security weaknesses. These now threaten to disrupt various cyber attack systems.

Average Cost Of A Data Breach Highest In The U.S.

Average total cost of a data breach by country in 2018



CC BY ND
@StatistaCharts Source: IBM

Forbes statista

The number of cyberattacks has grown rapidly because companies now experience about 1,636 cyberattacks every week during 2024, which represents a 30% growth from last year. The typical data breach now costs businesses \$4.88 million to resolve while cybercriminal activities will result in \$9.5 trillion of global losses during 2024. This will rise to \$10.5 trillion in 2025. The main security risk for vital sectors like energy, and healthcare comes from ransomware attacks, which combine with extortion and phishing threats.

1.1 Rationale

This report is motivated by the rising risk management challenges that confront contemporary business entities in a digital and networked world. Due to the fast pace of technological development, regulatory requirements and dependence on information systems, structured risk management becomes significant for the overall stability and security of companies nowadays. A well-articulated view of risk management frameworks and processes helps organizations to recognize, evaluate and manage risks efficiently. Accordingly, this research aims to investigate risk management and

control processes to facilitate informed decision making and enhance organizational sustainability.

1.2 Aims and Objectives

2. Literature Review

2.1 Risk Management Frameworks

Risk management framework represents a systematic method which supports businesses in both identifying and evaluating and mitigating and monitoring risks. The framework guarantees organizations maintain consistent risk management practices while connecting risk management goals to their business targets and regulatory requirements. Companies with strong risk management frameworks can effectively handle dynamic risks while using data analysis to safeguard their operational success and future development. (metricstream, 2023)



Figure 3 Risk Management Framework (Villanueva, 2024)

[2.1.1 ISO 31000 Risk Management Framework](#)

[2.1.2 COSO Enterprise Risk Management \(ERM\)](#)

[2.1.3 ISO 27005 – Information Security Risk Management](#)

2.2 Risk Management Process

Risk Management functions as a structured method which identifies and assesses and controls financial and operational and capital risks that affect an organization. These risks may arise from many areas, including financial instability, legal issues, errors in strategic planning, accidents, and even natural calamities. (McGrath, 2023)



Figure 4 Risk Management Process (Horvath, May 27 2025)

For Example - If a key developer in a software project falls ill, collaborative tools allow the team to continue smoothly. Organizations that use a defined process with adequate resources are able to decrease negative effects and achieve superior results. (McGrath, 2023)

[2.2.1 Risk Identification](#)

[2.2.2 Risk Assessment](#)

[2.2.3 Risk control](#)

3. Literature Review summary

The literature highlights that risk management frameworks such as ISO 31000, COSO ERM, and ISO/IEC 27005 provide a structured approach to identifying, assessing, and controlling organizational risks. The frameworks enable organizations to connect their risk management activities with their business targets and regulatory requirements, which helps them make better decisions. The risk management process allows organizations to find their risks at the beginning stage while they can rank these risks. This results in decreased losses and stabilized business activities and improved organizational strength. A proactive risk management system stands as a vital requirement to defend organizational resources, which will lead to business success that lasts through time.

4. Case Studies

4.1 Case Study I SolarWinds supply chain attack

4.1.1 Background

The SolarWinds supply chain attack, uncovered in December 2020, was a highly sophisticated cyber-espionage operation attributed to Russia's SVR (APT29/Cozy Bear). Attackers compromised SolarWinds' software build process and inserted the Sunburst backdoor into legitimate Orion updates. These malicious updates were distributed to around 18,000 customers, including U.S. government agencies, Fortune 500 companies, and critical infrastructure organizations. The attack primarily aimed at long-term espionage, allowing attackers to covertly access networks and exfiltrate sensitive data over several months. (aquasec, January 18, 2023) (Raglani, June 11, 2021)

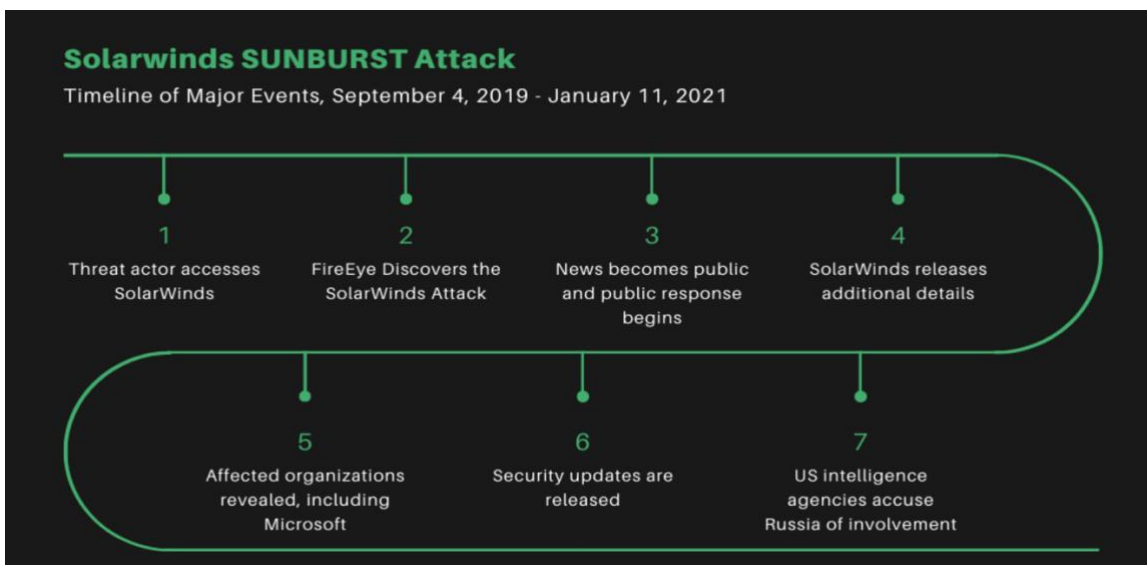


Figure 5 Timeline of the SolarWinds Supply Chain Attack (Burkett, January 19th, 2021)

4.1.2 Issue Identification

The SolarWinds attack exposed critical flaws in supply chain security and risk management. During the software build, attackers inserted malware into unsigned DLLs, evading integrity checks and going unnoticed for more than nine months. Poor monitoring, an excessive dependence on outside vendors, lax access controls, and the lack of multi-factor authentication in vital systems were some of the main vulnerabilities. (Arney, October 17, 2021)



Figure 6 The Anatomy of the SolarWinds Attack Chain (cyberark, 2/23/2021)

Following the incident, SolarWinds was subject to legal action, SEC regulatory scrutiny, and requirements for increased software bill of materials (SBOM) transparency. The breach highlighted the necessity of zero-trust architectures in supply chains and increased secondary risks, such as follow-on attacks via exposed data. (Raglani, June 11, 2021)

4.1.3 Mitigation Risk Management using ISO 27005 Framework

ISO/IEC 27005 provides a flexible framework for managing information security risks, which could have mitigated the SolarWinds attack by emphasizing supply chain vulnerabilities. In this instance, the procedure is reduced to three main stages: risk assessment, risk treatment with monitoring, and context establishment and risk identification. This focuses on proactive supply chain controls, which is consistent with the lessons learned from the breach.



Figure 7 Simplified ISO/IEC 27005 Risk Management Process (Forêt, September 11, 2023)

The SolarWinds risk management approach follows three phases: identifying critical assets and risks, assessing the likelihood and impact of threats such as the Sunburst attack, and applying mitigation measures. Controls like code signing, SBOMs, zero-trust segmentation, SIEM monitoring, vendor diversification, and risk transfer are used to reduce exposure and support continuous threat detection and protection. (cbiz, October 20, 2021)

4.1.4 Case Study Summary

The SolarWinds attack demonstrated how supply chain vulnerabilities without proper defence measures resulted in extensive spying activities while organizations failed to discover these threats and their vendor relationships remained unmonitored.

Organizations need to apply a shortened version of ISO 27005 which focuses on early risk detection and complete evaluation and strong risk management to stop these incidents from occurring while building an ongoing security monitoring system for software systems. The worldwide adoption of secure-by-design practices has become a direct result of this particular case.

4.2 Case Study II Colonial Pipeline ransomware attack

4.2.1 Background

The 2021 Colonial Pipeline ransomware attack showed that U.S. critical infrastructure systems contained essential cybersecurity flaws because attackers gained access through a single VPN account which lacked multi-factor authentication. The DarkSide ransomware group forced Colonial Pipeline to stop operations for five days between May 7 and 12, 2021, when they encrypted systems and stole almost 100 gigabytes of data. The attackers demanded 75 Bitcoin (≈\$4.4 million), which Colonial paid to accelerate recovery. (Hall, 2021) (Easterly, 2023)

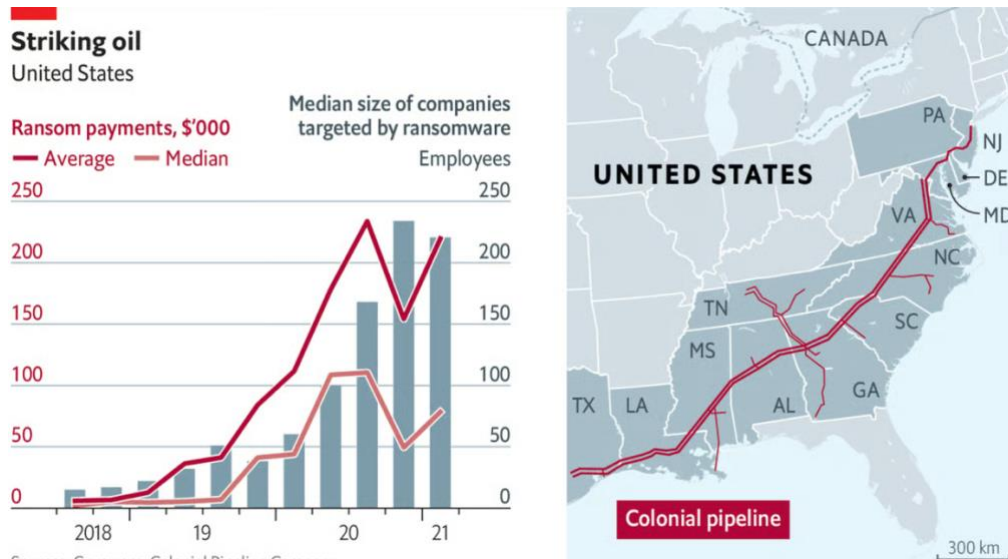


Figure 8 Ransomware attack on Colonial Pipeline (economist, May 10th 2021)

The shutdown caused fuel shortages throughout the country, which led people to buy fuel frantically while prices rose by 4 to 6 cents per gallon. The situation led to emergency declarations across 17 U.S. states and produced a total economic impact of approximately \$1.5 billion. The U.S. Department of Justice managed to recover 63.7 Bitcoin, which equals about \$2.3 million.

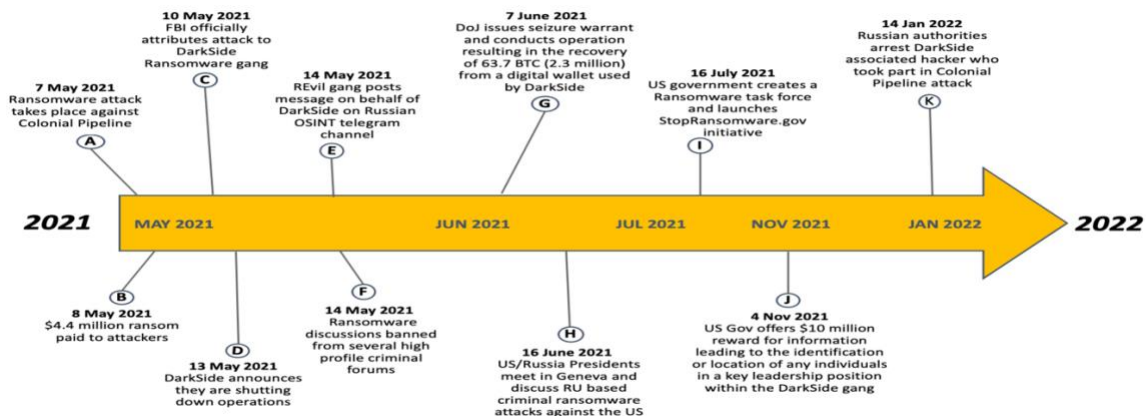


Figure 9 Timeline of attack (DiMaggio, 2022)

The attack exposed major weaknesses in credential storage methods and network separation between IT and operational technology systems, and ransomware defense systems. The attack forced the government to create stronger cybersecurity regulations, which showed critical infrastructure systems need security measures that combine risk

management with authentication systems and resilience-based controls. (Shier, Juni 28, 2021) (Hall, 2021)

4.2.2 Issue Identification

The Colonial Pipeline breach revealed major weaknesses in cybersecurity and risk management. Attackers used a security gap in the old VPN system through a single stolen password because the system lacked multi-factor authentication. (Hall, 2021)

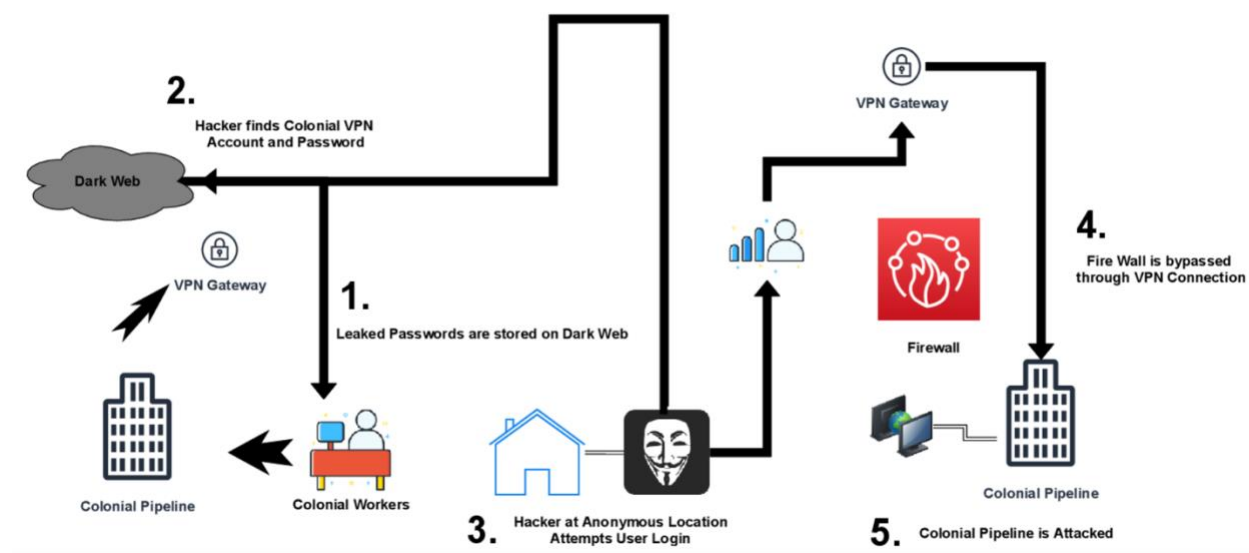


Figure 10 Colonial pipeline breach (iso, 2022)

Hackers obtained a Colonial Pipeline employee's VPN password from a leak on the dark web. They used this valid login to bypass the firewall, gain remote access to the network, and launch a devastating ransomware attack that shut down the pipeline. (Hall, 2021)

The incident led to major fuel shortages and a \$4.4 million ransom payment, highlighting the critical risk of compromised remote access credentials. (Olorunlana, 2025)

4.2.3 Mitigation Risk Management using ISO 27005 Framework

The ISO/IEC 27005 standard provides an organized repetitive system which helps organizations handle their information security risks. The Colonial Pipeline attack would have been prevented if the organization had used this system to discover and handle its information security risks before the incident occurred. The system operates according to ISO 27001 standards by providing particular risk management solutions. These protect vital pipeline infrastructure (Robertson, 19 May 2021) . The framework's phases get applied to the case study which follows below.

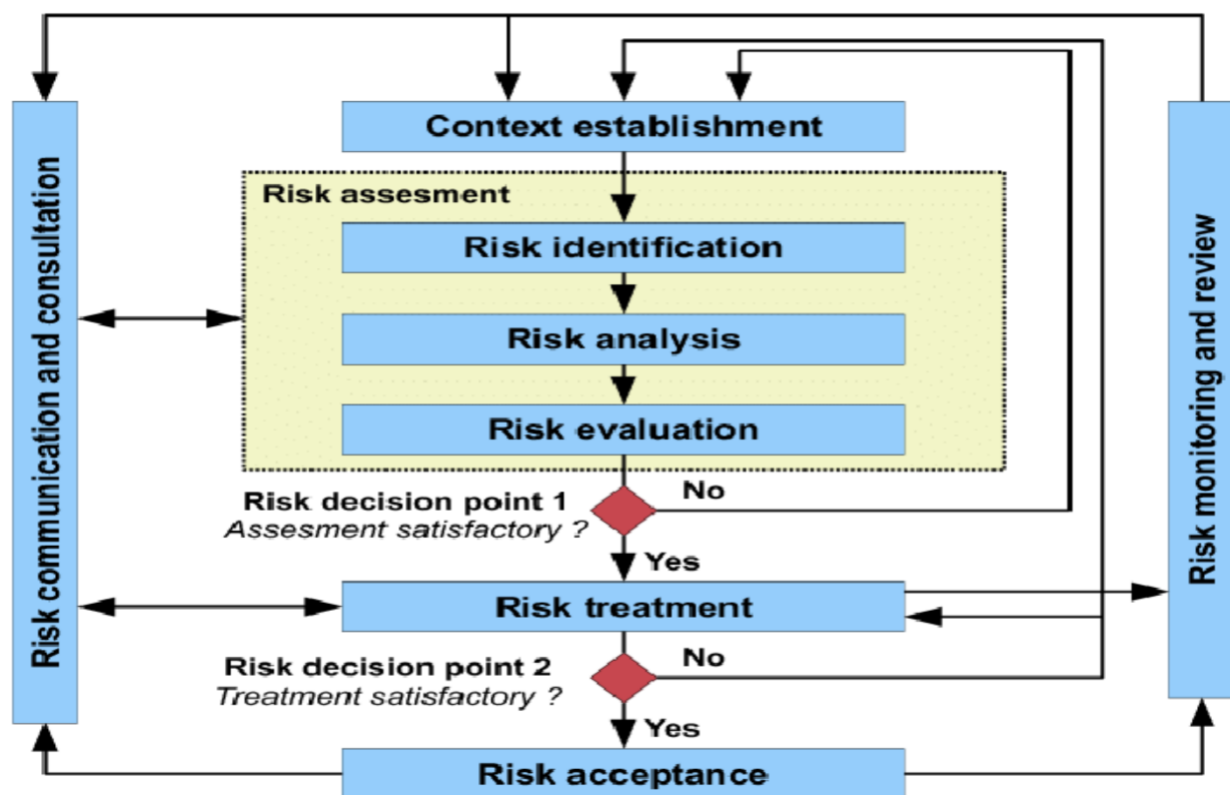


Figure 11 ISO/IEC 27005 Risk Management Process Diagram (Alazzawi, 2021)

The five stages of the Colonial Pipeline risk management process, which adheres to ISO 27005, are: identifying critical assets and threats; evaluating risks like out-of-date VPNs and weak authentication; putting controls in place like MFA, network segmentation, and cyber insurance; formally accepting residual risks with management approval; and continuously monitoring through SIEM tools and audits. When combined, these stages improve critical infrastructure defense against cyberattacks.

4.2.4 Case Study Summary

The 2021 Colonial Pipeline ransomware attack stopped operations for five days, stole about 100 GB of data, and had an economic impact of \$1.5 billion by taking advantage of a single VPN account without multi-factor authentication. Colonial recovered 63.7 Bitcoin after paying 75 Bitcoin (~4.4 million).

The hack revealed flaws in ransomware defences, IT/OT network segregation, and credential management. The attack might have been avoided and critical infrastructure resilience increased by implementing ISO 27005 for risk identification, assessment, and mitigation—such as segmenting networks and enforcing MFA.

4. References

Bibliography

Aven, T., 16 August 2016. *sciencedirect*. [Online]

Available at:

<https://www.sciencedirect.com/science/article/pii/S0377221715011479?via%3Dihub>

iso, 2018. *iso.org*. [Online]

Available at: <https://www.iso.org/obp/ui/en/#iso:std:iso:31000:ed-2:v1:en>

Horvath, I., May 27 2025. *invensislearning*. [Online]

Available at: https://www.invensislearning.com/blog/risk-management-process-steps/?utm_source=chatgpt.com

metricstream, 2023. *metricstream*. [Online]

Available at: <https://www.metricstream.com/learn/risk-management-framework-and-components.html>

Villanueva, E., 2024. *auditboard*. [Online]

Available at: <https://auditboard.com/blog/risk-management-framework>

metricstream, n.d. *metricstream*. [Online]

Available at: <https://www.metricstream.com/learn/iso-31000-framework-guide.html>

iso, 2018. *iso*. [Online]

Available at: <https://www.iso.org/standard/65694.html>

ERM, C., 2004. *famu.edu*. [Online]

Available at: https://www.famu.edu/administration/chief-operating-officer/enterprise_risk_management/erm_publications/erm_toolbox/COSO%20ERM%20Overview.pdf?utm_source=chatgpt.com

Williams, C., March 11, 2019. *strategicdecisionsolutions*. [Online]

Available at: <https://strategicdecisionsolutions.com/coso-erm-guidance/>

PECB, n.d. *PECB.COM*. [Online]

Available at: <https://pecb.com/en/education-and-certification-for-individuals/iso-iec-27005>

ISO, 2022. *ISO.COM*. [Online]

Available at: <https://www.iso.org/standard/80585.html>

metricstream, 2024. *metricstream*. [Online]

Available at: <https://www.metricstream.com/learn/risk-identification.html>

Kenton, W., nov 23 , 2025. *investopedia*. [Online]

Available at: <https://www.investopedia.com/terms/r/risk-assessment.asp>

riskpal, n.d. *riskpal*. [Online]

Available at: <https://www.riskpal.com/risk-assessment-matrices/>

safetyculture, 25 Sept 2025. *safetyculture*. [Online]

Available at: <https://safetyculture.com/topics/risk-management/risk-control>

Sekol, M., 2023. *esgadvocate*. [Online]

Available at: https://esgadvocate.substack.com/p/interconnected-risks-and-the-challenge?utm_source=chatgpt.com

McGrath, A., 2023. *ibm*. [Online]

Available at: <https://www.ibm.com/think/topics/risk-management>

aquasec, January 18, 2023. *aquasec*. [Online]

Available at: <https://www.aquasec.com/cloud-native-academy/supply-chain-security/solarwinds-attack/>

Raglani, R. D. L. M. A. M. A. A. H. A., June 11, 2021. *arnoldporter*. [Online]

Available at: <https://www.arnoldporter.com/en/perspectives/advisories/2021/06/lessons-learned-from-the-solarwinds-cyberattack>

fortinet, 2023. *fortinet*. [Online]

Available at: <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>

Burkett, D., January 19th, 2021. *kiuwan*. [Online]

Available at: <https://www.kiuwan.com/blog/solarwinds-hack-timeline/>

Arney, O. A., October 17, 2021. *ollisakersarney*. [Online]

Available at: <https://ollisakersarney.com/blog/cyber-case-study-solarwinds-supply-chain-cyberattack>

cyberark, 2/23/2021. *cyberark*. [Online]

Available at: <https://www.cyberark.com/resources/blog/the-anatomy-of-the-solarwinds-attack-chain>

cbiz, October 20, 2021. *cbiz*. [Online]

Available at: <https://www.cbiz.com/insights/article/cybersecurity-lessons-learned-solarwinds>

Forêt, C., September 11, 2023. *C-RISK*. [Online]

Available at: <https://www.c-risk.com/blog/iso-27005>

economist, May 10th 2021. *economist*. [Online]

Available at: <https://www.economist.com/graphic-detail/2021/05/10/ransomware-attacks-like-the-one-that-hit-colonial-pipeline-are-increasingly-common>

Hall, C. T., 2021. *cyberdefensereview army*. [Online]

Available at:

[https://cyberdefensereview.army.mil/Portals/6/Documents/2021 summer cdr/02 Reed erHall_CDR_V6N3_2021.pdf](https://cyberdefensereview.army.mil/Portals/6/Documents/2021%20summer%20cdr/02%20ReederHall_CDR_V6N3_2021.pdf)

Shier, J., Juni 28, 2021. *sophos.com*. [Online]

Available at: <https://www.sophos.com/de-de/blog/what-it-security-teams-can-learn-from-the-colonial-pipeline-ransomware-attack>

Easterly, j., 2023. *cisa*. [Online]

Available at: <https://www.cisa.gov/news-events/news/attack-colonial-pipeline-what-weve-learned-what-weve-done-over-past-two-years>

dentsu, 2023. *dentsu*. [Online]

Available at: <https://www.dentsu.com/news-releases/ad-spend-growth-tracks-ahead-of-the-economy>

Olorunlana, T. J., 2025. *researchgate*. [Online]

Available at:

[https://www.researchgate.net/publication/387104186 Analysis of the Colonial Pipeline Cybersecurity Incident](https://www.researchgate.net/publication/387104186_Analysis_of_the_Colonial_Pipeline_Cybersecurity_Incident)

Robertson, 19 May 2021. *isms*. [Online]

Available at: <https://www.isms.online/iso-27001/how-the-colonial-pipeline-hack-makes-the-case-for-iso-27001/>

Alazzawi, F. R. Y., 2021. *researchgate*. [Online]

Available at: [https://www.researchgate.net/figure/Information-security-risk-management-process-Source-ISO-IEC-27005-2018 fig1 389261989](https://www.researchgate.net/figure/Information-security-risk-management-process-Source-ISO-IEC-27005-2018_fig1_389261989)

Alazzawi, F. R. Y., 2021. *researchgate*. [Online]

Available at: [https://www.researchgate.net/figure/Information-security-risk-management-process-Source-ISO-IEC-27005-2018 fig1 389261989](https://www.researchgate.net/figure/Information-security-risk-management-process-Source-ISO-IEC-27005-2018_fig1_389261989)

5. Appendix

5.1 Aims and Objectives

The report aims to perform a detailed assessment of risk management systems and risk control frameworks which organisations apply in their modern operational and digital environments. Organisations that depend on complex information systems and interconnected infrastructures must implement effective risk management to protect their assets and maintain compliance with regulations and operational stability. The report establishes a systematic approach to detect risks and evaluate them before implementing control measures through established methods and industry standards.

The specific objectives are as follows:

- To explore the theoretical foundations of risk management
- To critically review major risk management frameworks
- To analyse commonly used risk assessment methodologies
- To examine risk control strategies
- To identify sector-specific risk challenges

5.2. ISO 31000 Risk Management Framework

ISO 31000 functions as a worldwide risk management standard which provides organizations with essential principles and guidelines for successful risk handling. (iso, 2018) Issued by the International Organization for Standardization, it is applicable to all organizations, regardless of size, sector, or industry. This provides a thorough, organized system for identifying, evaluating, treating, and monitoring risks. (metricstream, n.d.)

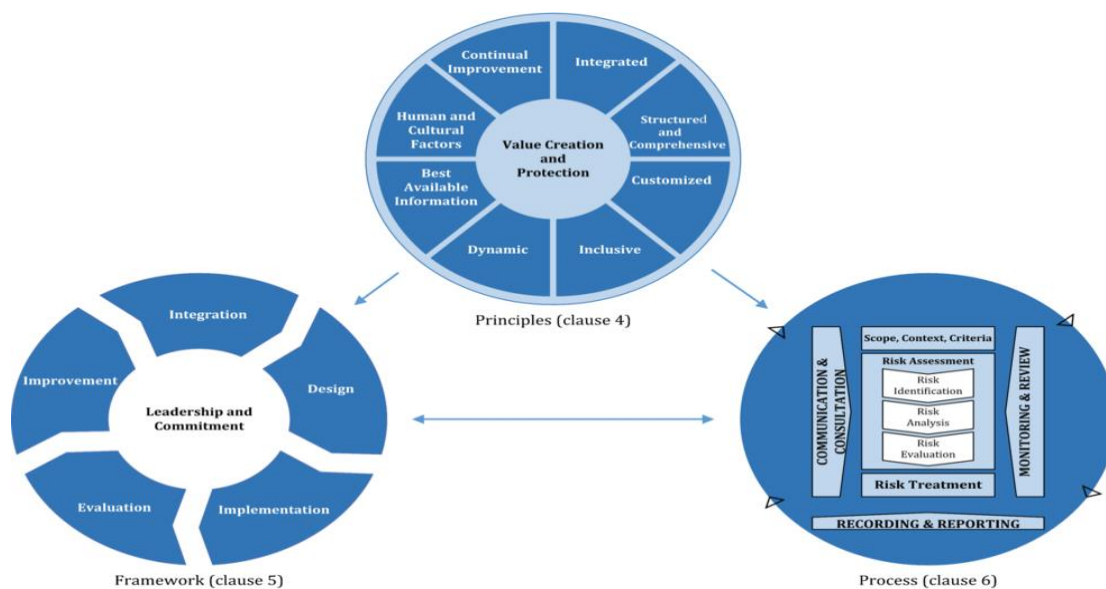


Figure 12 Principles, framework and process (iso, 2018)

ISO 31000 implementation for risk management delivers multiple advantages to organizations which seek to handle uncertainty and make better choices. The ISO 31000 framework establishes a systematic risk management approach which operates transparently and with accountability to boost organizational performance and protect both reputation and organizational resilience. (metricstream, n.d.)

5.3 COSO Enterprise Risk Management (ERM)

COSO Enterprise Risk Management (ERM) explains how organizations should manage risk while planning and achieving their goals. It shows that risk management should be part of everyday decision-making, not a separate activity. The framework helps organizations understand how risks can affect strategy, performance, and objectives. (ERM, 2004)



Figure 13 Enterprise Risk Management (Williams, March 11, 2019)

COSO ERM focuses on leadership responsibility, setting clear risk appetite, identifying and prioritizing risks, taking proper actions to control them, and regularly reviewing performance. Overall, it helps organizations make better decisions, reduce surprises, and improve long-term success. (ERM, 2004)

5.4 ISO 27005 – Information Security Risk Management

ISO/IEC 27005 delivers guidance about risk management for information security to assist organizations in deploying ISO/IEC 27001-based information security management systems (ISMS). The framework presents a systematic method to discover and evaluate and manage information security risks in all types of organizations. (ISO, 2022)

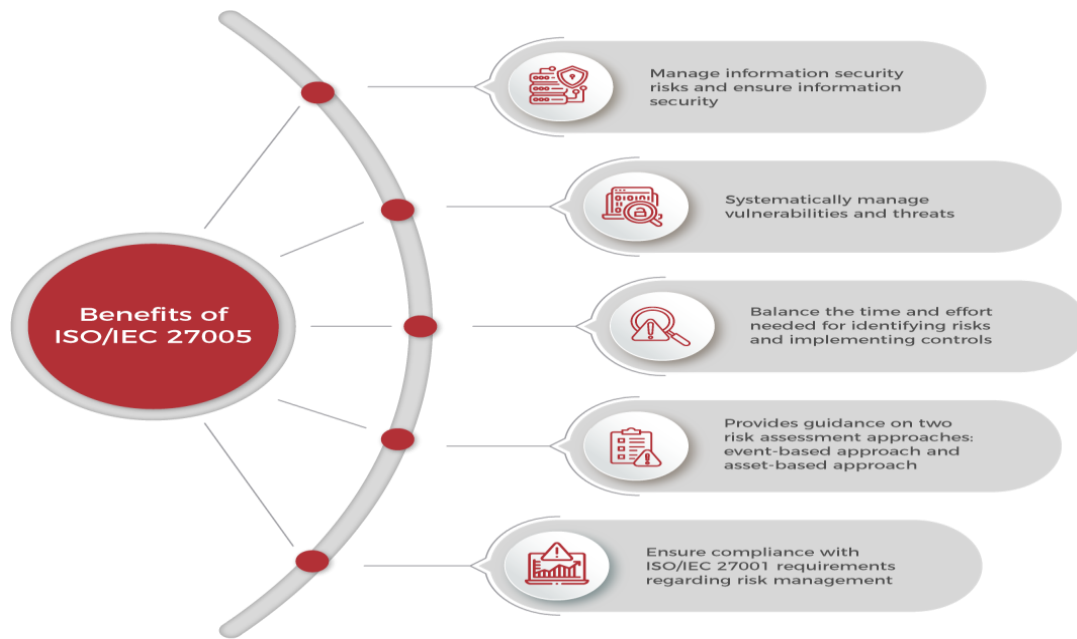


Figure 14 5 Benefits of ISO/IEC 27005 (PECB, n.d.)

Contemporary cyber threats change constantly which makes it necessary to manage information security risks to safeguard assets and maintain business operations.

Through its guidance ISO/IEC 27005 enables organizations to integrate risk management effectively into their ISMS while meeting standards of ISO/IEC 27001 and ISO 31000 to perform proactive threat management instead of reactive responses. (ISO, 2022)

5.5 Risk Identification

The systematic process of risk identification enables organizations to identify potential threats which might disrupt their achievement of goals. Such risks can arise from internal operations, market changes, regulatory shifts, or external factors like natural disasters or regional upheavals. (metricstream, 2024)

BENEFITS OF RISK IDENTIFICATION

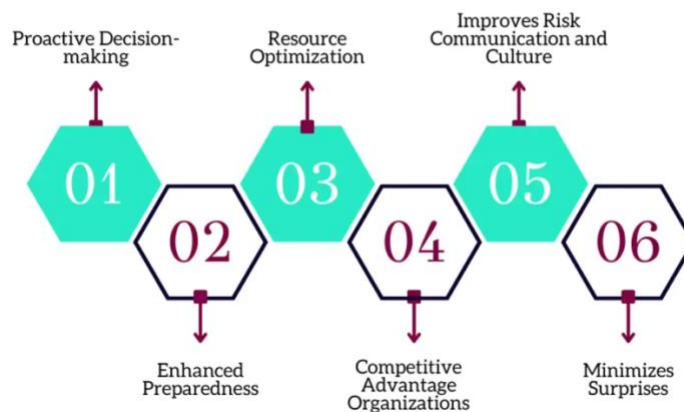


Figure 15 Benefits of risk identification (metricstream, 2024)

Risk identification helps organizations find and reduce threats which leads to better project results. Early risk detection enables businesses to establish superior preparedness against difficulties which leads to better strategic choices for risk management that produce better results and faster achievement of their goals. (metricstream, 2024)

5.6 Risk Assessment

Risk assessment evaluates the likelihood and impact of potential losses to determine whether an investment or asset is viable. Risk assessment uses qualitative and

quantitative approaches to analyze risks. This helps organizations select their best risk management methods. (Kenton, nov 23 , 2025)

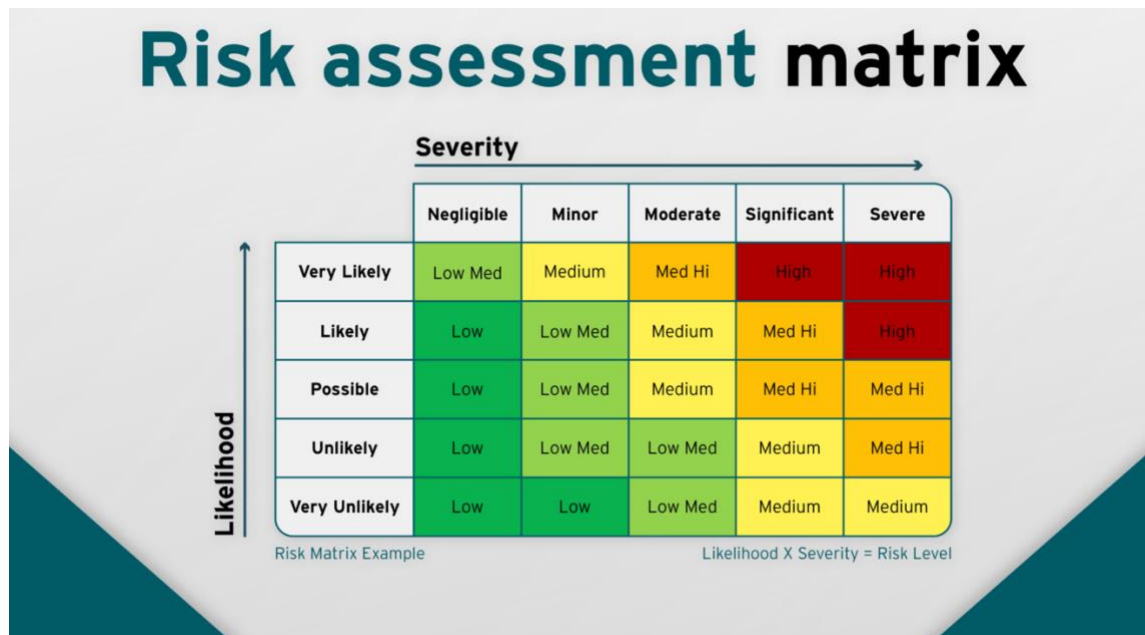


Figure 16 Assessment matrix (riskpal, n.d.)

A risk assessment matrix is a popular tool for visualising and evaluating risk. A risk assessment matrix usually appears as a chart or table which shows likelihood and severity (impact) through a structured grid system to help users assess risks quickly. (riskpal, n.d.)

5.7 Risk control

Risk control is the process undertaken by a business that aims at ensuring that risks, which could affect the business when it operates, can be controlled. Safety hazards and financial threats and public reputation threats are all included in this category. It involves strategic planning and execution to mitigate adverse outcomes, ensuring the smooth operation of processes and projects. (safetyculture, 25 Sept 2025)

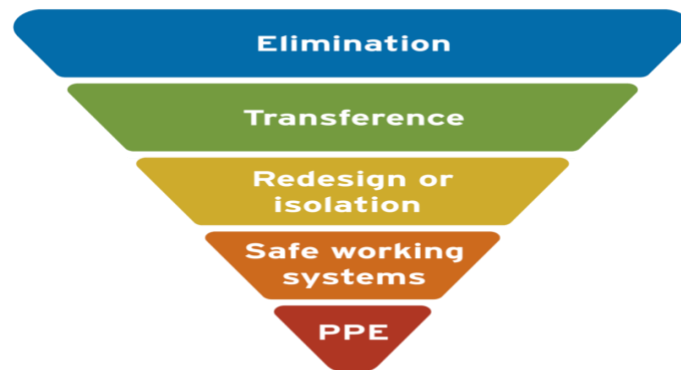


Figure 17 Risk Control (riskpal, n.d.)